

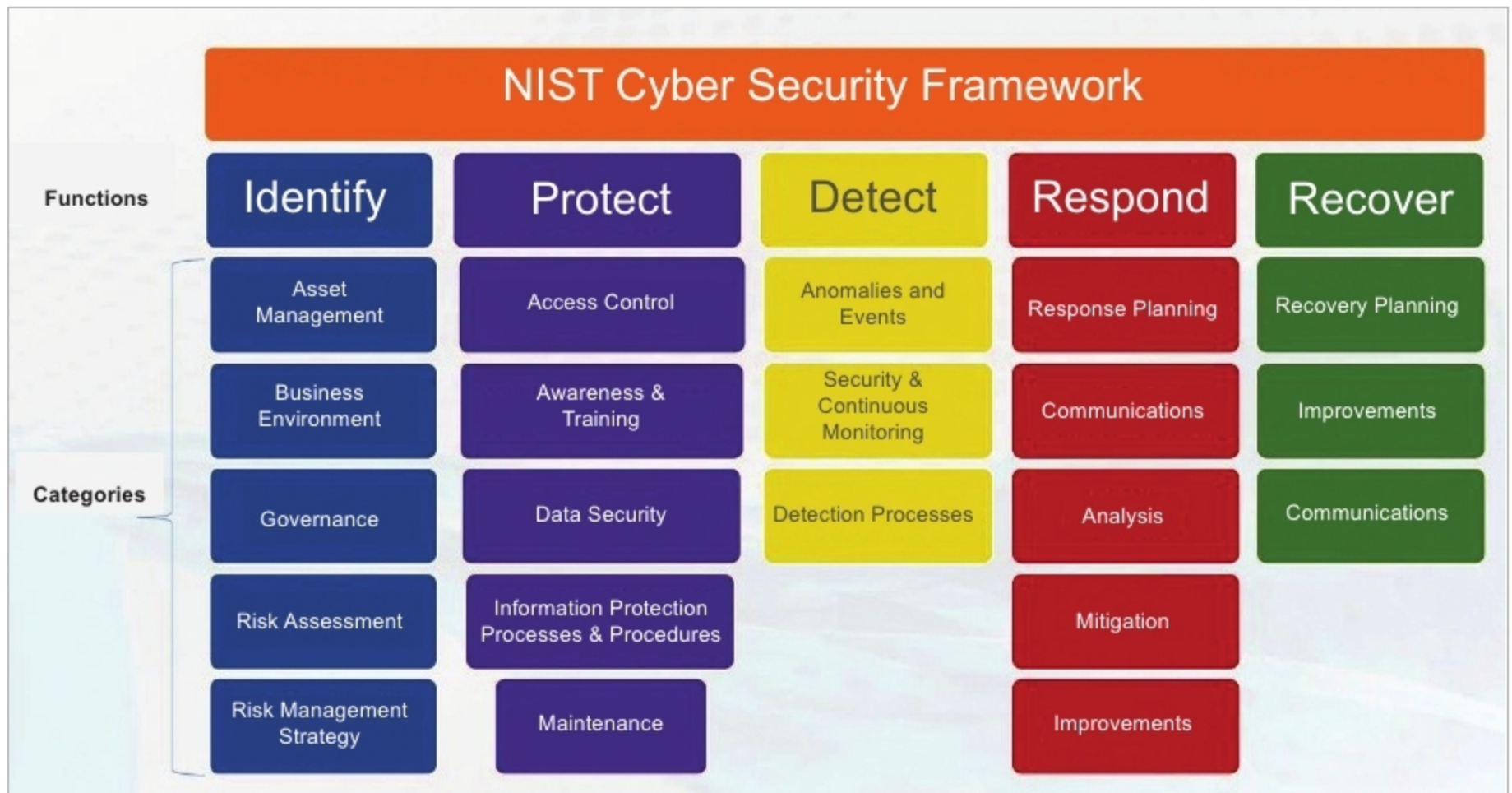


Figure 1: The NIST Framework

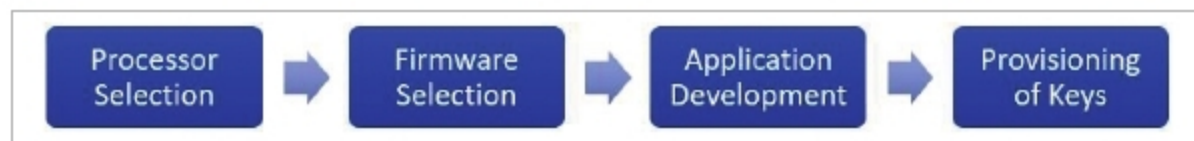


Figure 2: The data security process

standard definitions:

- Institute of Electrical and Electronic Engineers (IEEE) - The PHY and data link layer standards
- Internet Engineering Task Force (IETF) - Networking protocols from Layer 3 and above
- International Standard Organization (ISO) - Defines standards for many domains
- International Electrotechnical Commission (IEC) - Electrical and electronic products
- ISO/IEC 27000 family of standards - Jointly defined by ISO and IEC, these are information security management system (ISMS) standards
- International Society of Automation (ISA) - Defines standards for automation
- ISA Security Compliance Institute (ISCI) or isasecure - A part of the ISA group, this defines standards for industrial automation control systems.

It provides the following certifications in alignment with IEC-62443:

- EDSA - Embedded Device Security Assurance
- SSA - System Security Assurance
- SDLA - Security Development Lifecycle Assurance
- viii. IEC-62443 or ISA-99 - Security of Industrial Control System (ICS) networks. This standard was developed by the International Society of Automation (ISA) and taken over by IEC for further development.

The NIST framework: A single solution to ensure security?

The National Institute of Standards and Technology (NIST) is a non-regulatory agency of the United States Department of Commerce. One of the objectives of NIST is to help organisations to better understand and improve how they manage cyber security risks by proposing security

guidelines. They have released a cyber security framework document [see Reference 6] which covers all aspects of the subject — security functions, categories, sub-categories and the standards associated with them.

The framework defines five major functions as listed below (Figure 1):

- Identify: To identify what needs to be protected, such as systems, assets, data and capabilities.
- Protect: Implement appropriate safeguards to ensure delivery of critical infrastructure services.
- Detect: Implement appropriate activities to identify the occurrence of a security event.
- Respond: Implement the appropriate activities when facing a detected security event.
- Recover: Implement the appropriate activities to restore the affected services.

Organisations need to go through all the sub-categories and references for developing the security requirements, which should also align with their business goals. This careful analysis should result in a set of security requirements that is called a profile.